



한성과학고등학교 수학과학체험전

2026-05-21 (목)

학교:

이름:

사이버 방탈출 – 보안 취약점을 찾아라!

학습목표: 웹페이지의 기본 구조와 개발자 도구를 이해하고 보안 취약점의 원리와 방어 방법을 체험한다.

참고사항: 아래에 주어진 글은 설명에서 언급한 내용을 정리해 둔 것이므로 모르는 것이 있거나 더 알아보고 싶은 부분이 있을 때 참고하는 용도로 사용하면 된다. 모든 내용을 꼼꼼히 읽을 필요는 없다.

※ **주의사항:** 이 활동은 허가된 실습 사이트에서만 진행하며, 실제 웹사이트나 다른 사람의 계정에 같은 방법을 적용하거나 민감한 정보를 찾으려 시도해서는 안 된다.

1. 웹페이지의 구성 요소

웹페이지는 여러 요소가 함께 작동하여 만들어진다. HTML은 제목, 문단, 버튼 등과 같은 기본 구조를 만든다. CSS는 글자색, 배경색, 크기 등의 디자인을 담당한다. JavaScript는 버튼을 누르는 등 입력을 주었을 때 화면이 바뀌거나, 값을 저장하는 등의 여러 가지 작동들을 담당한다.

'주석'이란 코드나 기능에 대한 설명을 위해 개발자가 작성한 메모이다. 이는 실제로 웹사이트의 기능에 아무런 영향을 주지 않는다.

JS: `// 이 표시 뒤에 주석을 작성합니다.`

HTML: `<!-- 이 표시 사이에 주석을 작성합니다. -->`

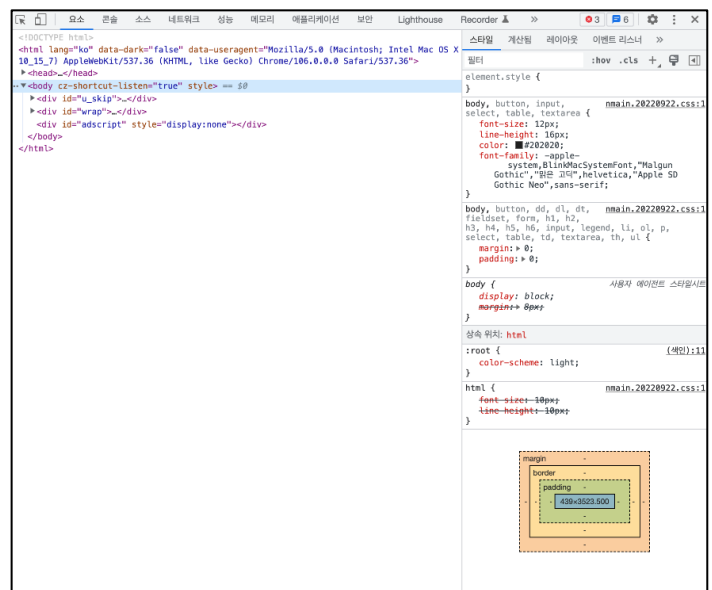
여기서 가장 중요한 점은 화면에 보이는 내용만으로 보안이 결정되지 않는다는 것이다. 버튼을 숨기거나 글자색을 바꾸는 것은 화면 표시만 바꾸는 것이다. 실제로 로그인에 성공했는지, 관리자 권한이 있는지, 어떤 기능을 사용할 수 있는지는 서버에서 확인해야 안전하다.



2. 개발자 도구란?

개발자 도구는 브라우저에서 제공하는 기능으로 웹페이지의 구조, 사용된 파일, 저장된 정보 등을 볼 수 있다. 보통 'F12' 키를 누르거나 '검사' 항목을 이용하여 접근할 수 있다. 'Elements'와 'Source' 항목에서 코드를 확인할 수 있고 'Application' 항목으로 들어가 'Local Storage'와 'Session Storage' 항목에서 저장된 값들을 확인할 수 있다. 보이는 코드에서 원하는 항목을 찾기 위해서는 'Ctrl + F'를 이용할 수 있다.

이렇게 모든 구성 파일과 내용을 확인할 수 있으므로 웹페이지를 구성하는 코드와 주석에는 민감한 정보를 포함하면 안 된다.



3. 웹 보안 취약점이란?

웹 보안 취약점은 웹사이트가 만들어지는 과정에서 생긴 약점이다. 웹사이트는 글자와 버튼을 보여주는 화면뿐 아니라, 로그인 정보를 확인하고, 사용자의 권한을 판단하고, 데이터를 저장하는 여러 기능들을 한다. 이 과정에서 중요한 정보를 너무 쉽게 볼 수 있게 해 두거나, 사용자가 값을 마음대로 변경할 수 있거나, 입력한 내용을 제대로 확인하지 않으면 심각한 보안 문제가 생길 수 있다.

4. 취약점의 예시

1) 클라이언트 코드나 주석에 중요한 정보가 남아있는 경우

위에서도 설명했듯이, 웹페이지를 구성하는 모든 파일과 코드, 주석은 공개되어 있으므로 여기에 중요하거나 민감한 정보가 작성되어 있다면, 심각한 보안 문제가 발생할 수 있다.

이 취약점을 막으려면 비밀번호, 관리자 주소, API 키, 서버 접속 정보 같은 민감한 정보는 HTML이나 JavaScript 코드에 넣지 않아야 한다. 중요한 정보는 사용자의 브라우저가 아니라 서버에서 안전하게 관리해야 한다. 일부 개발 도구는 작성된 코드를 읽기 어렵게 만드는 난독화를 지원하기도 한다.

2) 보안을 숨겨진 기능이나 페이지에 의존하는 경우

버튼, 메뉴, 페이지 주소를 화면에서 숨기는 것은 보안을 위한 충분한 방법이 아니다. 숨겨진 요소나 페이지의 단서가 코드 안에 남아 있을 수 있고, 주소를 알게 되는 경우도 생길 수 있다. 따라서 중요한 기능은 화면에서 숨기는 것에 의존하지 말고, 서버에서 사용자의 권한을 반드시 확인해야 한다.

3) Local Storage에 중요하거나 민감한 정보를 저장하는 경우

Local Storage는 웹사이트가 사용자의 브라우저 안에 간단한 정보를 저장할 수 있게 해 주는 기능이다. 예를 들어 사용자가 선택한 다크 모드 설정 같은 정보를 저장하는 데 사용할 수 있다. Local Storage에 저장된 값은 사용자의 브라우저 안에 저장되어 있기 때문에 사용자가 확인하거나 수정할 수 있다. 따라서 보안과 관련 없는 설정 값은 저장할 수 있지만, 로그인 여부, 관리자 권한, 계정 등급 같은 중요한 정보를 Local Storage 값으로 판단하면 위험하다.

4) 입력 값을 제대로 검증하지 않는 경우

웹사이트에는 로그인 창, 검색창, 댓글 입력창처럼 사용자가 글을 입력하는 곳이 많다. 웹사이트는 사용자가 입력한 내용을 서버로 보내고, 서버는 그 내용을 이용해 필요한 처리를 한다. 문제는 사용자의 입력 값을 항상 믿으면 안 된다는 점이다. 사용자가 입력한 내용이 예상과 다를 수 있고, 그 값을 안전하게 처리하지 않으면 보안 문제가 생길 수 있다.

그중 매우 유명한 취약점이 SQL injection이다. SQL은 데이터베이스에 질문하거나 명령을 내릴 때 사용하는 언어이다. 웹사이트는 로그인 정보를 확인하는 등 값을 찾을 때 데이터베이스를 사용한다. SQL injection은 사용자가 입력한 값이 단순한 글이 아니라 데이터베이스 명령어의 일부처럼 처리될 때 발생할 수 있는 취약점이다. 대표적인 예시로는 SQL에서의 주석을 의미하는 문자열 `--`를 이용하여 로그인 창의 ID 입력란에 `[ID] --`와 같이 입력하면 해당 ID의 계정으로 인증 없이 로그인할 수 있다.

이 취약점을 막으려면 서버는 사용자의 입력 값 길이와 형식을 확인해야 한다. 또한 데이터베이스에 접근할 때 입력 값을 SQL 명령문에 직접 이어 붙이지 않고, 입력 값을 데이터로 분리해서 처리하는 안전한 방식을 사용해야 한다.

5. 직접 해보기

주어진 주소로만 접속하여 활동한다.

진행이 막히거나 모르겠는 부분이 있으면 가까운 관계자에게 도움을 요청할 수 있다.

시놉시스

그동안 온갖 불법 행위를 저지르면서도 교묘하게 증거를 인멸해 처벌을 피해 가던 악덕 기업 '내븐'의 꼬리가 결국 밟혔다. 4월까지만 해도 증거 불충분으로 법망을 피해 가며 공분을 샀던 내븐이었지만, 바로 오늘 열린 한성과학고등학교 수학과학체험전에서 반전이 일어났다. 체험전에 참가한 중학생 수사관들이 내븐의 웹사이트에서 치명적인 취약점을 발견하고, 그동안 베일에 싸여 있던 불법 증거들을 무더기로 확보하는 데 성공한 것이다.

오늘 발행될 신문 기사에는 이 천재적인 중학생들이 내븐의 철옹성 같던 보안망을 무너뜨리고 관리자 페이지를 뚫어낸 실제 해킹 과정이 생생하게 실릴 예정이다. 내일 아침 신문 일면을 장식할 이 짜릿한 역전극의 주인공이 바로 여러분이다. 지금 한성과학고 수학과학체험전 부스에서 여러분만의 천재적인 감각으로 신문 기사 속 빈칸에 숨겨진 비밀을 직접 밝혀내고, 악덕 기업 내븐을 무너뜨릴 결정적 증거를 손에 쥔 차례다. 여러분의 손으로 정의를 구현하고 내일 아침 뉴스 헤드라인을 직접 완성할 기회다.

※ 실제로는 해킹을 통한 증거 수집은 불법이므로 원칙적으로 법적 증거능력이 인정되지 않으며, 정보통신망법 위반 등으로 처벌을 받을 수 있다.

0) 튜토리얼 - 숨겨진 관리자 페이지 찾기

_____ 방법을 통해 관리자 로그인 페이지에 접근했다.

1) 1단계 - 페이지 접근 권한 획득하기

_____에서 페이지 접근 암호를 획득하고 권한을 얻었다.

2) 2단계 - 관리자 권한 얻기

_____ 기법을 이용하여 관리자 계정으로 로그인에 성공했다.

3) 최종적으로 획득한 증거는 무엇인가?
